

PARECER/2025/19

I. Pedido

1. O Instituto da Segurança Social dos Açores, I.P.R.A., (ISSA, IPRA) submeteu à Comissão Nacional de Proteção de Dados (doravante CNPD), para parecer, o Protocolo a ser celebrado com o Instituto de Informática, I.P. (I.I.P.) e a Inspeção Regional do Trabalho, (IRT), regendo os termos em que ocorrerá o acesso pela IRT aos dados que integram as bases de dados do ISSA, I.P.R.A., nomeadamente de suporte ao planeamento e à execução da respetiva atividade, para a finalidade exclusiva da prossecução das competências que estão legalmente cometidas à IRT.
2. O pedido é efetuado ao abrigo do disposto no n.º 5 do artigo 5.º do Regime Jurídico da Atividade de Inspeção da Administração Direta e Indireta do Estado, aprovado pelo Decreto-Lei n.º 267/2007, de 31 de julho, na sua redação atual, para cumprimento da obrigação decorrente da alínea d) do n.º 3, do mesmo artigo 5.º do Decreto-Lei n.º 267/2007.
3. O Protocolo vigorará enquanto se mantiverem as condições legais e de facto que justificam a sua celebração, ou até que seja denunciado o que, a ocorrer, deverá ser feito na forma escrita e com antecedência mínima de um ano.
4. A CNPD emite parecer no âmbito das suas atribuições e competências, enquanto autoridade administrativa independente com poderes de autoridade para o controlo dos tratamentos de dados pessoais, conferidos pela alínea c) do n.º 1 do artigo 57.º, conjugado com a alínea b) do n.º 3 do artigo 58.º, e com o n.º 4 do artigo 36.º, todos do Regulamento (UE) 2016/679, de 27 de abril de 2016 - Regulamento Geral sobre a Proteção de Dados (RGPD), em conjugação com o disposto no artigo 3.º, no n.º 2 do artigo 4.º, e na alínea a) do n.º 1 do artigo 6.º, todos da Lei n.º 58/2019, de 8 de agosto, que executa na ordem jurídica interna o RGPD.

II. Apreciação

5. O Decreto-Lei n.º 276/2007, de 31 de julho, na sua redação atual, que aprovou o regime jurídico da atividade de inspeção na administração direta e indireta do Estado, na qual se inclui a atividade da IRT, determina que as pessoas coletivas públicas devem prestar aos serviços de inspeção toda a colaboração por estes solicitada para o desempenho da sua missão e, ainda, que o acesso à informação relevante para o exercício das respetivas atribuições, as categorias dos titulares e dos dados a analisar, a forma de comunicação e o respetivo tratamento, deve ser definido mediante protocolo a celebrar entre as respetivas entidades, sujeito a autorização da CNPD (artigo 5.º, n.º 1 e 4).

6. Note-se que, com a entrada em vigor do RGPD as competências da CNPD deixaram de compreender a autorização prévia de tratamentos de dados pessoais nos termos descritos (prevista na alínea b) do n.º 1 do artigo 23.º da Lei n.º 67/98, de 26 de outubro, revogada pela Lei n.º 58/2019, de 8 de agosto) pelo que a presente pronúncia decorre dos poderes consultivos previstos na alínea b) do n.º 3 do artigo 58.º do RGPD.

7. Para o desempenho da sua missão, a IRT necessita aceder à informação residente nas bases de dados ou sistemas de informação, utilizados pelo ISSA, I.P.R.A., no âmbito estrito das suas competências de autoridade de controlo e fiscalização do cumprimento das disposições legais, regulamentares e convencionais respeitantes às relações e condições de trabalho, designadamente as relativas à segurança e saúde no trabalho, tendo ainda como atribuições verificar os requisitos legais relativos à prestação de informação sobre a atividade social das empresa, tempos de trabalho, bem como conceder autorizações atinentes às relações de trabalho; propor medidas necessárias à superação das insuficiências ou omissões detetadas relativamente à inexistência ou inadequação das disposições normativas cujo cumprimento lhe incumbe assegurar; receber e tratar as comunicações e notificações respeitantes às condições de trabalho e às relações de trabalho que, nos termos da lei, lhe devam ser dirigidas; e exercer as demais atribuições que lhes estão legalmente cometidas - cfr. Decreto Regulamentar Regional n.º 20/2024/A, de 18 de novembro, em conjugação com a alínea i) do artigo 16.º e n.º 1 do artigo 20.º do Decreto Regulamentar Regional n.º 3/2024/A, de 11 de abril e n.º 3 do artigo 6.º do RGPD.

8. Define-se na cláusula 2.ª que “as categorias de dados sujeitos a tratamento” serão a identificação de entidades empregadoras; a identificação e atividade de entidades contratantes; a identificação de trabalhadores independentes; a identificação de trabalhadores por conta de outrem e respetiva qualificação e vinculação; as remuneração de trabalhadores por conta de outrem; as comunicações obrigatórias de doença profissional confirmadas no mês anterior, de acordo com o previsto no n.º 1 do artigo 143.º da Lei n.º 98/2009, de 4 de setembro.

9. É, ainda, afirmado nesta cláusula 2.ª que “o acesso aos dados é efetuado diretamente no Sistema de Informação através Social da Segurança Social (SISS), pelo número de segurança social (NISS) ou número de identificação fiscal (NIF)”.

10. Ora, o n.º 5. do artigo 35.º da CRP proíbe a atribuição de um número nacional único aos cidadãos, razão pela qual têm sido entendimento da CNPD que não possa ser o NIF utilizado como o “número nacional único”. Assim, a fim de evitar a violação dessa norma constitucional, e estando prevista a utilização do número do próprio Instituto da Segurança Social, deverá ser este o número a utilizar, não se mostrando adequado a utilização do NIF para identificação do profissional, devendo este número ser utilizado apenas para identificação junto da Administração Tributária e para os fins a ela respeitantes.

11. Já nos termos da cláusula 3.^a, *“o tratamento de dados pessoais objeto do [...] Protocolo tem como fundamento de licitude o disposto na alínea b) do n.º 2 do artigo 9.º do RGPD.”*

12. *De facto, embora nos termos do número 1 do artigo 9º os dados relativos a doenças profissionais sejam dados pertencentes a categorias especiais de dados cujo tratamento é, em regra, proibido, a verdade é que tal tratamento é possível quando esteja em causa uma das exceções previstas no n.º 2 daquele artigo, como é o caso, em que o fundamento de licitude para estes tratamentos de dados radica na alínea e) do n.º 1 do artigo 6.º, conjugado com o artigo 9.º, ambos do RGPD, na medida em que é necessário para o exercício de autoridade pública de que está investida a IRT - cfr. artigo 85.º do Decreto Regulamentar Regional n.º 20/2024/A, de 18 de novembro.*

13. Quanto aos demais dados, não pertencentes a categorias especiais de dados, o seu tratamento deve encontrar fundamento de licitude nos termos da alínea e) do n.º 1 do artigo 6.º do RGPD.

14. *No que concerne à forma como os dados serão acedidos, estabelece a cláusula 2.^a que “[o] acesso aos dados é efetuado diretamente no Sistema de Informação [...] da Segurança Social (SISS)”.*

15. No que respeita às modalidades de acesso que se efetuam por via digital, a CNPD recorda a obrigatoriedade de implementação de túneis IPsec, para garantia de confidencialidade dos dados. Sublinha-se ainda que as vias de acesso designadas para consulta de informação, devem oferecer garantias de auditabilidade que permitam, nomeadamente, aferir quem foi a pessoa que efetuou determinada pesquisa, bem como o motivo (e.g., referência ao número do processo que motivou a consulta).

16. Por outro lado, tendo a CNPD identificado um número crescente de ataques aos sistemas de informação, o que levou à divulgação da Diretriz/2023/1, relativa às medidas organizativas e de segurança aplicáveis aos tratamentos de dados pessoais, entende-se que, como boa prática deverão, com periodicidade adequada, ser efetuados testes de intrusão e avaliação de vulnerabilidades nas comunicações entre os outorgantes do protocolo em apreço o qual poderá incluir a definição de um procedimento formalizado para gerir incidentes de segurança dos dados, no qual se deve incluir a notificação da CNPD em caso de violação de dados pessoais originada nos acessos atribuídos.

17. Já quanto às credenciais de acesso deverá ser previsto um mecanismo que permita a para revogação das mesmas de forma rápida e eficaz quando, por quaisquer razões, um funcionário deixe de ter necessidade de acesso. (e.g. por ter deixado de desempenhar funções na IRT, por ter mudado de situação profissional dentro da IRT, etc.);

18. Por outro lado, a cláusula 15.^a refere que “[p]ara efeitos de acompanhamento da execução do presente Protocolo as partes podem designar os seus responsáveis.” E que “[t]odas as comunicações que devam

realizar-se ao abrigo do presente Protocolo são efetuadas por escrito, enviadas por correio eletrónico ou por correio registado, [...]”.

19. Ora, cumpre aos responsáveis pelo tratamento, quando abranja as categorias especiais de dados a que se refere o artigo 9.º, n.º 1 do RGPD, manter um registo atualizado dos acessos concedidos, com informação sobre o nome e os contactos do responsável pelo tratamento, as finalidades do tratamento, a descrição das categorias de titulares de dados e categorias dos dados pessoais, as categorias de destinatários a quem os dados foram os serão divulgados, se possível os prazos previstos para o apagamento das diferentes categorias de dados e uma descrição geral das medidas técnicas e organizativas no domínio da segurança referidas no artigo 32.º, n.º1 do RGPD, em conformidade com o artigo 30.º do mesmo Regulamento, bem como o enquadramento legal do exercício de funções de interesse público ou o exercício da autoridade pública de que a IRT está investida.

20. Assim, ainda que os responsáveis pelo tratamento identificados no Protocolo possam indicar, dentro da sua organização, quem ficará com o encargo de acompanhar a execução do Protocolo e que possa funcionar como interlocutor, deverá ter-se em atenção que é ao responsável pelo tratamento que caberá o cumprimento das obrigações previstas no artigo 30.º do RGPD.

21. Importa, por fim, referir que o Protocolo, pelo seu carácter geral, não dispensa uma avaliação casuística das condições do acesso às bases de dados, para o efeito de verificação do cumprimento do princípio da necessidade e do princípio da minimização dos dados consagrados na alínea c) do n.º 1 do artigo 5.º do RGPD. Nessa medida, para além dos elementos elencados na cláusula 2.ª, o Protocolo deve ainda prever a obrigação da contextualização para cada acesso, designadamente a indicação do número do processo da IRT no âmbito do qual é necessário aceder aos diferentes tipos de dados, desde logo para permitir aferir do cumprimento daqueles princípios.

22. Duas precisões devem ser introduzidas no texto do Protocolo: por um lado no n.º 2 da cláusula 11.ª, uma vez que existem dois corresponsáveis, quando se diz “Compete ao responsável pelo tratamento”, deve dizer-se “responsáveis”, deixando claro que são competências que cabem a qualquer dos dois responsáveis, incluindo no que respeita ao contacto com os titulares para exercício dos seus direitos.

23. Por outro lado, na cláusula 17.ª, no que respeita ao direito aplicável em matéria de proteção de dados, deve ser incluído, também, a Lei n.º 58/2019, de 8 de agosto, que executa na lei interna o Regulamento Geral sobre a Proteção de Dados.

24. Assim cumprirá corrigir, quanto aos direitos dos titulares, a alínea d) da cláusula 6.ª, de modo a esclarecer que estes direitos podem ser exercidos junto de qualquer um dos responsáveis.

25. A mesma correção deverá ser introduzida no n.º 2 da cláusula 11.ª, devendo ficar claro que as obrigações aí previstas cabem a ambos os responsáveis pelo tratamento.

III. Conclusão

26. Assim, com os fundamentos acima expostos, a CNPD recomenda:

- a. A introdução no Protocolo da obrigação de contextualizar cada acesso, designadamente impondo a indicação do número do processo da IRT no âmbito do qual o tratamento de dados é realizado;
- b. A consagração de implementação de túneis IPsec para garantia de confidencialidade dos dados devendo as vias de acesso oferecer garantias de auditabilidade;
- c. Que seja criada uma cláusula relativa às credenciais de acesso, onde se inclua o mecanismo previsto para revogação das mesmas;
- d. A realização, com periodicidade adequada, de testes de intrusão e avaliação de vulnerabilidades nas comunicações entre os outorgantes do protocolo em apreço;
- e. No âmbito dessa disponibilização de consulta aos dados pessoais recomenda-se a definição de um procedimento formalizado para gerir incidentes de segurança dos dados, o qual deve incluir a notificação da CNPD, em caso de violação de dados pessoais originada nos acessos atribuídos.

Aprovado na reunião de 11 de fevereiro de 2025

**MARIA CÂNDIDA
OLIVEIRA**

Assinado de forma digital

por MARIA CÂNDIDA
OLIVEIRA

Dados: 2025.02.12 14:12:01

Z

Maria Cândida Oliveira (Vogal que substitui a Presidente)